COBRA7 | SUMMARY

ملخص OWASP Top 10 (إصدار 2021)

العشرة مخاطر الأشهر في أمن تطبيقات الويب بشكل مبسط

ملخص لأهم 10 مخاطر في تطبيقات الويب حسب إصدار OWASP Top 10 لسنة 2021. لكل خطر: يعني إيه، مثال، والحل.

A01 — كسر التحكم في الصلاحيات (Broken Access Control)

مستخدم يوصل لبيانات أو وظايف مش من حقه.

مثال: تغيير رقم id في الرابط يفتح طلب عميل تاني (IDOR).

الحل: تحقق من الصلاحية على السيرفر في كل طلب، والافتراضي منع.

A02 — فشل التشفير (Cryptographic Failures)

بيانات حساسة من غير تشفير أو بتشفير ضعيف.

مثال: باسوورد متخزن بـ MD5 من غير salt، أو موقع شغال على HTTP.

الحل: فعّل TLS، وخزّن الباسوورد بـ bcrypt أو Argon2، ومتخزنش اللي مش محتاجه.

A03 — الحقن (Injection)

بيانات المستخدم بتتفسّر كأنها أمر (SQL, OS, XSS).

مثال: كتابة ' OR '1'='1 في حقل الدخول.

الحل: استخدم Parameterized Queries، ورمّز المخرجات، وافحص المدخلات.

A04 — تصميم غير آمن (Insecure Design)

العيب في فكرة النظام نفسها مش في سطر كود.

مثال: استرجاع باسوورد بسؤال سهل التخمين، أو من غير حد للمحاولات.

الحل: Threat Modeling من أول التصميم، وحدود واضحة لكل عملية حساسة.

A05 — ضبط غير آمن (Security Misconfiguration)

إعدادات افتراضية أو خدمات مفتوحة أو رسائل أخطاء مفصلة.

مثال: صفحة أدمن شغالة بباسوورد افتراضي، أو Stack Trace ظاهر للزائر.

الحل: Hardening، شيل غير المستخدم، ومراجعة دورية للإعدادات.

A06 — مكتبات قديمة فيها ثغرات (Vulnerable and Outdated Components)

استخدام مكتبات أو إطارات عمل فيها ثغرات معروفة.

مثال: موقع شغال على إصدار قديم من مكتبة اتصلّحت فيها ثغرة من سنين.

الحل: اعمل جرد للمكتبات، وحدّث باستمرار، واستخدم أدوات فحص الـDependencies.

A07 — ضعف تسجيل الدخول (Identification and Authentication Failures)

تخمين الباسوورد، أو جلسات غير محمية، أو غياب MFA.

مثال: السماح بمحاولات دخول لا نهائية.

الحل: فعّل MFA، وحدّد عدد المحاولات، وأدر الجلسات صح.

A08 — سلامة البرمجيات والبيانات (Software and Data Integrity Failures)

تحديثات أو مكتبات من مصدر غير موثوق، أو Deserialization غير آمن.

مثال: سكريبت خارجي بيتحمّل من غير التحقق منه.

الحل: تحقق من التوقيع والمصدر، وأمّن خط الـCI/CD.

A09 — ضعف التسجيل والمراقبة (Security Logging and Monitoring Failures)

الهجوم بيحصل ومحدش بيشوفه.

مثال: محاولات دخول فاشلة بالآلاف من غير أي تنبيه.

الحل: سجّل الأحداث الحساسة، وركّب تنبيهات، وراجع اللوجات.

A10 — تزوير الطلبات من السيرفر (Server-Side Request Forgery (SSRF))

السيرفر بيطلب رابط يحدده المهاجم فيوصل لخدمات داخلية.

مثال: رابط معاينة صورة بيخلي السيرفر يزور خدمة داخلية.

الحل: قائمة بيضاء للوجهات، وامنع الوصول للشبكة الداخلية من الخدمة.